

THIRD-PARTY RISK MANAGEMENT

Third-Party / Vendor Cybersecurity Risk Assessment

Summit Technology Solutions (STS) | Contract Renewal Review

Organization	Northstar Financial Group (fictional)
Vendor	Summit Technology Solutions (STS) - fictional managed IT provider
Assessment Type	Critical Third-Party / Vendor Cybersecurity Risk Assessment
Analyst	Ryan Bryant
Decision	Conditional Go - renewal blocked pending mandatory controls

Portfolio note: This document is a fictional cybersecurity assessment simulation. No real company or vendor was assessed.

Document Control

Document status	Final portfolio assessment
Assessment scope	Critical managed IT provider renewal review
Vendor criticality	Critical
Current-state risk	4.1 / 5 - Severe High / Critical range
Target residual risk	2.1 / 5 - Moderate
Recommendation	Conditional Go - renewal blocked pending mandatory controls

Executive Summary

Northstar Financial Group relies on Summit Technology Solutions (STS) for privileged server administration, firewall and VPN management, Microsoft 365 support, remote connectivity, incident-response support, and other operational functions. Because compromise or prolonged unavailability of STS could materially affect Northstar confidentiality, integrity, availability, and recovery capability, STS is classified as a Critical vendor.

The assessment identified significant current-state weaknesses in privileged identity, incident notification, security evidence availability, data handling, subprocessor transparency, downstream recovery assurance, and exit/portability rights. The weighted current-state score is 4.1/5, placing the relationship in a Severe High/Critical range. After negotiated contract controls and remediation requirements are implemented and validated, the target residual risk falls to approximately 2.1/5 (Moderate).

Final Recommendation

CONDITIONAL GO. Do not renew the existing agreement unchanged. Renewal may proceed only after mandatory security terms are executed and critical technical controls are validated. If STS refuses any renewal blocker, Northstar should initiate transition planning to an alternate provider.

1. Vendor Profile and Criticality

Dependency / Access	Present	Risk Significance
Privileged server access	Yes	Compromise could provide direct administrative access.
Firewall administration	Yes	Affects perimeter/network security and policy enforcement.
VPN administration	Yes	Affects remote access and trusted connectivity.
Microsoft 365 administration	Some	Potential identity, email, and tenant security impact.
Customer data access	Potential / incidental	Sensitive data may be exposed during support.
Employee data access	Potential / incidental	Support activity may expose regulated or confidential records.
Remote network connectivity	Yes	Creates a trusted third-party path into Northstar.
Business continuity dependency	Yes	Vendor availability affects recovery and support.
Incident-response dependency	Yes	Vendor cooperation may be required during major incidents.

Criticality Determination

Critical. Vendor compromise is more concerning than simple unavailability because STS trusted access could allow an attacker to affect confidentiality, integrity, and availability simultaneously.

2. Assessment Methodology

The review used a structured questionnaire, risk scoring, contract control analysis, and simulated negotiation to determine current-state and target residual risk. Scores range from 1 (Low) to 5 (Critical). Category weights reflect the level of trusted access STS holds in Northstar.

Category	Weight	Reason for Weight
Identity & Privileged Access	25%	Highest exposure from trusted administrative access.
Data Protection & Encryption	20%	Sensitive data may be handled during support and backup activity.
Incident Response & Breach Notification	20%	Northstar depends on timely vendor transparency during incidents.
BC/DR & Supply Chain	25%	STS relies on downstream providers and supports Northstar continuity.
Exit & Portability	10%	Northstar must remain able to leave the vendor without operational lock-in.

3. Questionnaire Findings - Identity & Privileged Access

Q1 - MFA exceptions for two legacy privileged engineer accounts

Current risk score: 5/5. Required treatment: Eliminate direct privileged MFA exceptions or place legacy tooling behind an MFA-protected privileged access gateway before renewal.

Q2 - Some customer administration performed using engineers' standard corporate identities

Current risk score: 4/5. Required treatment: Require separate named administrative identities for all customer administration.

Q3 - Shared emergency administrator account stored in company password manager

Current risk score: 4/5. Required treatment: Restrict access, log/approve every use, rotate after use, and move toward named emergency identities.

Q4 - Privileged permissions reviewed annually

Current risk score: 4/5. Required treatment: Quarterly privileged access certification plus immediate event-driven reviews for role changes and separation.

Q5 - Employee access normally disabled within 24 hours of separation

Current risk score: 4/5. Required treatment: Revoke interactive and customer access at the effective separation time; preserve account records only as needed.

Identity Category Assessment

Current category score: 4.2/5 (High). Primary drivers are privileged MFA exceptions, use of standard accounts for administration, a shared emergency identity, annual-only privileged access reviews, and delayed offboarding.

4. Questionnaire Findings - Data Protection & Encryption

Q6 - Temporary troubleshooting exports may be stored unencrypted on engineer workstations

Current risk score: 4/5. Required treatment: Require company-managed encrypted storage, controlled workspaces, secure deletion, and no uncontrolled local copies.

Q7 - Senior infrastructure administrators can access key-management systems

Current risk score: 4/5. Required treatment: Limit key access to named personnel with business need, MFA, separate privileged identities, logging, review, and JIT where practical.

Q8 - 90-day post-termination retention with some backups retained up to one year

Current risk score: 4/5. Required treatment: Define data categories, storage locations, legal basis, retention periods, protections, and destruction dates contractually.

Q9 - Engineers may download customer files to managed laptops for troubleshooting

Current risk score: 4/5. Required treatment: Permit only under documented conditions on encrypted, centrally managed endpoints with EDR/DLP, logging, and prompt secure deletion.

Q10 - Certificates of destruction provided only if specifically requested

Current risk score: 3/5. Required treatment: Require destruction evidence at termination and for material deletion events; document residual backup expiration.

Current category score: 3.8/5 (High). STS uses encryption for core services, but customer protection becomes inconsistent when troubleshooting files, endpoint downloads, key-management access, retention, and destruction evidence are considered.

5. Questionnaire Findings - Incident Response & Breach Notification**Q11 - No guaranteed incident notification timeline**

Current risk score: 5/5. Required treatment: Contractually require notification within 72 hours of discovery of a relevant suspected or confirmed incident.

Q12 - STS generally waits for preliminary investigation before customer notification

Current risk score: 5/5. Required treatment: Require notification when an incident reasonably could affect Northstar, before final impact confirmation.

Q13 - Evidence provided only where commercially reasonable; log availability varies

Current risk score: 5/5. Required treatment: Guarantee preservation and scoped export of Northstar-relevant logs; 24-hour incident / 48-hour routine delivery targets.

Q14 - Annual ransomware tabletop; broader technical exercise evidence unclear

Current risk score: 3/5. Required treatment: Provide exercise results, corrective-action evidence, and broader testing across credential compromise, cloud outage, recovery, and supplier failure.

Q15 - Northstar can revoke STS access but may interrupt managed services

Current risk score: 4/5. Required treatment: Maintain Northstar-controlled emergency admin access, documented failover, and independent ability to revoke all STS identities/sessions.

Critical Category

Current category score: 4.4/5. Undefined notification timing, delayed disclosure, and uncertain evidence availability create multiple renewal-blocking risks.

6. Questionnaire Findings - BC/DR & Supply Chain**Q16 - STS backs up critical systems to a separate cloud provider, but Northstar recovery rights are unclear**

Current risk score: 3/5. Required treatment: Document Northstar-related backup scope, encryption, access, restoration rights, and recovery if STS itself is unavailable.

Q17 - Backups monitored daily; full restoration testing annually

Current risk score: 3/5. Required treatment: Define backup type/frequency/retention and expand technical recovery validation based on service criticality and major changes.

Q18 - Complete subprocessor list is not routinely provided

Current risk score: 4/5. Required treatment: Provide a complete list of material subprocessors affecting Northstar data, systems, privileged access, or critical services.

Q19 - No advance customer notice for routine material subprocessor changes

Current risk score: 4/5. Required treatment: Provide at least 30 days advance notice for material changes with documented objection and termination rights.

Q20 - Supplier assurance relies on questionnaires and certifications

Current risk score: 3/5. Required treatment: Use evidence-based, risk-tiered reassessment and maintain Northstar audit/assurance rights for critical downstream suppliers.

Q21 - Recovery capability varies by critical provider and service

Current risk score: 4/5. Required treatment: Maintain and share a critical-provider dependency/recovery register and notify Northstar of material changes.

Current category score: 3.5/5 (High). STS demonstrates some continuity maturity, but Northstar lacks sufficient visibility into backup recovery rights, downstream critical-provider dependencies, subprocessor changes, and evidence-based supplier assurance.

7. Exit & Portability Risk**Q22 - Transition costs, configuration ownership, and portability rights are inadequately defined**

Current risk score: 5/5. Required treatment: Guarantee Northstar-specific data/configuration portability, credentials and architecture records, defined migration pricing, and deletion only after validated handoff.

Exit Principle

Intellectual-property ownership and operational portability are separate issues. STS may retain generic tools and methods, but Northstar must receive everything required to operate its own environment or transition to another qualified provider.

8. Detailed Vendor Risk Register

Q	Category	Current Finding	Score	Required Treatment	Renewal Gate?
1	Identity & Privileged Access	MFA exceptions for two legacy privileged engineer accounts	5	Eliminate direct privileged MFA exceptions or place legacy tooling behind an MFA-protected privileged access gateway before renewal.	Yes
2	Identity & Privileged Access	Some customer administration performed using engineers' standard corporate identities	4	Require separate named administrative identities for all customer administration.	Condition / Evidence
3	Identity & Privileged Access	Shared emergency administrator account stored in company password manager	4	Restrict access, log/approve every use, rotate after use, and move toward named emergency identities.	Condition / Evidence
4	Identity & Privileged Access	Privileged permissions reviewed annually	4	Quarterly privileged access certification plus immediate event-driven reviews for role changes and separation.	Condition / Evidence
5	Identity & Privileged Access	Employee access normally disabled within 24 hours of separation	4	Revoke interactive and customer access at the effective separation time; preserve account records only as needed.	Yes
6	Data Protection & Encryption	Temporary troubleshooting exports may be stored unencrypted on engineer workstations	4	Require company-managed encrypted storage, controlled workspaces, secure deletion, and no uncontrolled local copies.	Condition / Evidence
7	Data Protection & Encryption	Senior infrastructure administrators can access key-management systems	4	Limit key access to named personnel with business need, MFA, separate privileged identities, logging, review, and JIT where practical.	Condition / Evidence
8	Data Protection & Encryption	90-day post-termination retention with some backups retained up to one year	4	Define data categories, storage locations, legal basis, retention periods, protections, and destruction dates contractually.	Condition / Evidence
9	Data Protection & Encryption	Engineers may download customer files to managed laptops for troubleshooting	4	Permit only under documented conditions on encrypted, centrally managed endpoints with EDR/DLP, logging, and prompt secure deletion.	Condition / Evidence
10	Data Protection & Encryption	Certificates of destruction provided only if specifically requested	3	Require destruction evidence at termination and for material deletion events; document residual backup expiration.	Condition / Evidence
11	Incident Response & Breach Notification	No guaranteed incident notification timeline	5	Contractually require notification within 72 hours of discovery of a relevant suspected or confirmed incident.	Yes
12	Incident Response & Breach Notification	STS generally waits for preliminary investigation before customer notification	5	Require notification when an incident reasonably could affect Northstar, before final impact confirmation.	Yes

13	Incident Response & Breach Notification	Evidence provided only where commercially reasonable; log availability varies	5	Guarantee preservation and scoped export of Northstar-relevant logs; 24-hour incident / 48-hour routine delivery targets.	Yes
14	Incident Response & Breach Notification	Annual ransomware tabletop; broader technical exercise evidence unclear	3	Provide exercise results, corrective-action evidence, and broader testing across credential compromise, cloud outage, recovery, and supplier failure.	Condition / Evidence
15	Incident Response & Breach Notification	Northstar can revoke STS access but may interrupt managed services	4	Maintain Northstar-controlled emergency admin access, documented failover, and independent ability to revoke all STS identities/sessions.	Yes
16	BC/DR & Supply Chain	STS backs up critical systems to a separate cloud provider, but Northstar recovery rights are unclear	3	Document Northstar-related backup scope, encryption, access, restoration rights, and recovery if STS itself is unavailable.	Condition / Evidence
17	BC/DR & Supply Chain	Backups monitored daily; full restoration testing annually	3	Define backup type/frequency/retention and expand technical recovery validation based on service criticality and major changes.	Condition / Evidence
18	BC/DR & Supply Chain	Complete subprocessor list is not routinely provided	4	Provide a complete list of material subprocessors affecting Northstar data, systems, privileged access, or critical services.	Yes
19	BC/DR & Supply Chain	No advance customer notice for routine material subprocessor changes	4	Provide at least 30 days advance notice for material changes with documented objection and termination rights.	Yes
20	BC/DR & Supply Chain	Supplier assurance relies on questionnaires and certifications	3	Use evidence-based, risk-tiered reassessment and maintain Northstar audit/assurance rights for critical downstream suppliers.	Condition / Evidence
21	BC/DR & Supply Chain	Recovery capability varies by critical provider and service	4	Maintain and share a critical-provider dependency/recovery register and notify Northstar of material changes.	Yes
22	Exit & Portability	Transition costs, configuration ownership, and portability rights are inadequately defined	5	Guarantee Northstar-specific data/configuration portability, credentials and architecture records, defined migration pricing, and deletion only after validated handoff.	Yes

9. Current-State Weighted Risk Score

Category	Score	Weight	Weighted Contribution	Rating
Identity & Privileged Access	4.20	25%	1.050	High
Data Protection & Encryption	3.80	20%	0.760	High
Incident Response & Breach Notification	4.40	20%	0.880	Critical
BC/DR & Supply Chain	3.50	25%	0.875	High
Exit & Portability	5.00	10%	0.500	Critical

Weighted overall current-state score: 4.065/5, rounded to 4.1/5. This places STS in the Severe High/Critical range before remediation and contract changes.

10. Mandatory Renewal Blockers

- Defined 72-hour notification requirement for relevant suspected or confirmed incidents, measured from discovery.
- Notification before STS completes its full investigation when an incident reasonably could affect Northstar.
- Guaranteed preservation and delivery of Northstar-relevant security logs and evidence.
- MFA-gated privileged access before renewal; no direct privileged MFA exemption.
- Immediate separation-time revocation of interactive and customer access.
- Northstar-controlled ability to revoke STS privileged access without losing ownership/control of the environment.
- Complete disclosure of material subprocessors and 30-day advance notice of material changes.
- Defined recovery capabilities for STS critical downstream providers.
- Guaranteed Northstar-specific data, configuration, credential, and documentation portability at exit.

Decision Rule

If STS refuses any mandatory renewal blocker, Northstar should not renew the agreement and should begin controlled vendor-transition planning.

11. Contract Negotiation Outcomes

Area	STS Position	Northstar Final Position	Result
Incident notification	STS proposed 72 hours after confirmed material impact.	Northstar accepted 72 hours only when measured from discovery of an incident that reasonably could affect Northstar; final written report required even if Northstar is ultimately unaffected.	Agreement
Logs & evidence	STS proposed selected extracts with no delivery guarantee and “commercially reasonable” language.	Northstar accepted scoped exports rather than direct multi-tenant platform access; 24-hour incident delivery, 48-hour routine audit delivery, and preservation on investigation notice.	Agreement
Privileged MFA	STS requested nine months of continued privileged MFA exceptions.	Northstar rejected. STS revised to an MFA-protected privileged access gateway within 45 days, named engineers, logged sessions, and legacy-tool replacement within six months.	Agreement pending validation
Material subprocessors	STS proposed 30-day post-change notice with no objection rights.	Northstar required 30-day advance notice, documented security objection rights, and termination of affected services without unreasonable penalty if unresolved.	Agreement with clarification
Exit & portability	STS asserted ownership of some templates, automation and methodologies.	Northstar accepted STS ownership of generic IP but required all Northstar-specific configurations, data, credentials, architecture records, service inventories, defined migration pricing, and validated handoff before deletion.	Agreement

12. Target Residual Risk After Agreed Controls

Category	Current	Target	Weight	Target Contribution	Target Rating
Identity & Privileged Access	4.20	2.00	25%	0.500	Moderate
Data Protection & Encryption	3.80	2.00	20%	0.400	Moderate
Incident Response & Breach Notification	4.40	2.20	20%	0.440	Moderate
BC/DR & Supply Chain	3.50	2.17	25%	0.542	Moderate
Exit & Portability	5.00	2.00	10%	0.200	Moderate

Weighted target residual score: 2.083/5, rounded to 2.1/5 (Moderate). This score is a target condition only; Northstar should not treat the risk as reduced until contractual terms are executed and technical controls are validated.

13. Remediation and Validation Plan

Priority / Time	Required Action	Owner	Validation Evidence
Before renewal	Execute incident notification, log/evidence, subprocessor, portability, and access-revocation contract language.	Legal / Procurement / Security	Signed contract amendment.
Before renewal	Deploy and test MFA-gated privileged access path; prohibit direct privileged MFA exemption.	STS / Northstar Security	Access test, authentication logs, session attribution.
Before renewal	Validate immediate separation-time offboarding for STS privileged users.	STS IAM	Sample offboarding evidence and procedure.
30 days	Provide complete material-subprocessor inventory and critical-provider dependency list.	STS Risk / Vendor Mgmt	Approved inventory and service mappings.
30 days	Formalize Northstar-relevant log retention and evidence preservation procedure.	STS Security	Retention matrix and evidence-request test.
60 days	Complete separate admin identity rollout and emergency-account governance improvements.	STS IAM	Access review and named-account inventory.
60 days	Document customer troubleshooting data controls, retention schedule, and deletion evidence.	STS Security / Privacy	Policy, endpoint controls, sample destruction record.
90 days	Expand supplier assurance and provide stronger recovery testing evidence.	STS Risk / BC/DR	Assessment package, restore-test results, corrective actions.
Quarterly	Privileged access certification and material vendor-change review.	STS + Northstar	Quarterly certification record.

14. Ongoing Third-Party Oversight

- Quarterly review of privileged STS access to Northstar systems.
- Quarterly review of material subprocessor changes and critical-provider dependencies.

- Annual formal vendor reassessment using evidence rather than questionnaire responses alone.
- Incident-driven reassessment whenever STS suffers a material security event or significant control failure.
- Periodic test of Northstar ability to revoke STS access while retaining emergency administrative control.
- Periodic transition-readiness review to verify current configurations, architecture records, credentials, and data exports remain obtainable.
- Formal management acceptance of residual risk after validation of required controls.

15. Final Renewal Recommendation

CONDITIONAL GO

Northstar should renew STS only after mandatory contractual requirements are executed and critical controls are validated. Once verified, the relationship may proceed at an estimated Moderate residual risk of approximately 2.1/5 with continuous oversight. Failure to accept or implement a renewal blocker changes the recommendation to NO-GO and triggers vendor transition planning.

Residual risk remains because Northstar will continue to depend on a critical managed service provider, STS will continue to use downstream cloud providers, the negotiated incident notification period is 72 hours rather than immediate, and some proprietary STS tooling will remain outside Northstar ownership. These risks are potentially acceptable only if Northstar retains operational control, transparency, evidence rights, and exit capability.

16. Portfolio / Interview Summary

This project demonstrates third-party risk management across vendor criticality, privileged access, data protection, breach notification, business continuity, subprocessor governance, exit planning, weighted risk scoring, contract negotiation, remediation prioritization, and residual-risk acceptance.

Resume Bullet

Performed a simulated critical-vendor cybersecurity assessment covering 22 control questions, scored STS at 4.1/5 current risk, negotiated renewal controls across incident notification, privileged MFA, evidence access, subprocessors, and exit rights, and reduced target residual risk to 2.1/5 (Moderate).

Interview Talking Points

- Why privileged vendor access made STS a Critical third party even though it was not a data-hosting-only vendor.
- Why “commercially reasonable” evidence language was rejected and replaced with measurable delivery targets.
- How compensating controls can temporarily reduce risk without accepting a long-term MFA exception.
- Why advance subprocessor notice and exit rights matter for supply-chain risk.
- How current risk, inherent risk, target residual risk, and actual validated residual risk differ.
- Why contract language is a cybersecurity control when the organization depends on another company.

Appendix A - Risk Scale

Score	Rating	Meaning
1	Low	Control is adequate; little additional action required.
2	Low-Moderate	Minor weakness or clarification needed.
3	Moderate	Meaningful gap requiring remediation.
4	High	Serious weakness; contractual remediation required.
5	Critical	Unacceptable without correction; potential renewal blocker.